

How Sortd gets purchases in: every option, with costs

Written 21 Sep 2026. Research done by web search on that day. Every price is quoted from the provider's own page unless marked "quote only". Nothing is guessed. "Not confirmed" means I could not find it on an official page.

Context: Google's OAuth team requires a CASA AL1 security assessment for `gmail.readonly` by 20 Dec 2026. Servers are acceptable. User privacy is the top priority. Markets: Australia and Singapore first, then US/UK.

1. Do we need CASA at all?

What it costs. TAC Security (Google's discounted partner): AL1 Basic **\$675** (2 re-check rounds), Premium **\$855** (unlimited re-checks). Enterprise AL1 \$4,500, AL2 \$5,400. Redone **every 12 months**. Google itself charges nothing; the lab bills you. - <https://tacsecurity.com/google-casa-cloud-application-security-assessment/> - <https://tacsecurity.com/esof-appsec-ada-casa-faqs/> - <https://support.google.com/cloud/answer/13463817>

Other labs (third-party blog, "as of 2024", unconfirmed): Leviathan \$800–1,200, NCC \$1,200+, Prescient \$1,000+, Bishop Fox \$1,500+. - <https://www.switchlabs.dev/post/casa-tier-2-tier-3-security-review-providers-pricing-and-the-cheapest-option>

What AL1 involves for Sortd. You run a static scan of the source (upload a zip), provide flow diagrams and scope details, fix findings, lab issues a letter. 2–3 weeks. - <https://appdefensealliance.dev/casa/tier-2/ast-guide>

The exemption argument. Google's restricted-scope page:

"If you store or transmit restricted scope data on servers, then you need to complete a security assessment." - <https://developers.google.com/identity/protocols/oauth2/production-readiness/restricted-scope-verification> - Same wording on <https://developers.google.com/workspace/gmail/api/auth/scopes>

Sortd has no server, so on that wording it is exempt. But the Cloud Console help page says every restricted-scope app needs an annual assessment, with no condition: - <https://support.google.com/cloud/answer/13465431>

Evidence from other developers: - 2019: a developer was verified without an assessment after moving to local-only storage. <https://groups.google.com/g/google-apps-script-community/c/iE0wi64rSe0> - March 2026: an iOS developer reports being refused; local-only "does not automatically waive" CASA. <https://security.googlecloudcommunity.com/google-security-operations-2/what-happened-to-local-app-gmail-api-access-7138> - 19 Sep 2026: "Subik" asked Google's forum the same question for on-device parsing. No answer yet. <https://discuss.google.dev/t/gmail-restricted-scope-is-the-casa-assessment-required-when-mail-is-processed-on-device-and-only-a-derived-subscription-list-reaches-our-server/398372>

Outcome not confirmed. Worth one email. If refused, fall back to another option.

Trap: if Sortd adds a server that touches Gmail data, the exemption argument dies, and the level can rise to AL2 (\$5,400).

If we skip it: Google can revoke tokens. App becomes "unverified": warning screen and a lifetime cap of 100 users. Testing status: 100 hand-added testers, sign-in expires every 7 days. -

<https://support.google.com/cloud/answer/7454865> -

<https://support.google.com/cloud/answer/15549945>

Which Gmail scopes are restricted: all of them that read mail (`gmail.readonly`, `gmail.metadata`, `gmail.modify`, `mail.google.com`). Only Gmail add-on scopes (`gmail.addons.current.message.readonly`) are merely "sensitive", and they only see the one message the user has open inside Gmail. Not usable for an iOS app. -
<https://support.google.com/cloud/answer/13464325>

2. What is already in the app (code scan)

- Gmail code is ~770 lines of ~16,900 Swift (4–5%): `GmailSync.swift`, `GoogleAuth.swift`, `GmailViews.swift`, `Keychain.swift`.
 - Receipt parsing (~1,000 lines: `EmailParsers`, `GenericReceipts`, `ReceiptAI`, `BankAlerts`, `EmailSync`) is source-agnostic. It takes `{id, from, subject, body, date}` and returns records. Any text source can feed it.
 - Already built without Google: Apple Pay tap logging via Shortcuts (`LogWalletTapIntent`), receipt camera OCR + on-device AI, CSV/PDF/statement import, quick text entry, backup restore.
 - Email bodies are never stored. Token in Keychain, `AfterFirstUnlockThisDeviceOnly`.
 - Min iOS 26. No share extension yet. No background fetch.
-

3. Every option

Privacy score 1–5, 5 = nothing leaves the phone.

A. Ask Google for the no-server exemption

- Privacy 5. Cost \$0. Effort: one email (drafted in `GoogleVerification.md`).
- Risk: may be refused. Outcome not confirmed.

B. Pay for CASA AL1 and keep Gmail sign-in

- Privacy 5 (nothing changes). Cost **\$675–855 every year**, flat regardless of users, plus 2–5 days/yr of your time. Best user experience (one sign-in, no setup).
- Risk: yearly forever; Google can still reject the video or use case separately.

C. Email forwarding inbox on Cloudflare (recommended replacement)

User creates a Gmail filter that auto-forwards receipts to `u-abc123@in.sortd.page`. A Cloudflare Email Worker reads the mail in memory, encrypts it to the phone's public key (HPKE, CryptoKit, iOS 17+), stores only ciphertext in R2 with a 24-hour expiry, sends a silent push, the phone fetches and deletes. Server never stores plaintext, never logs bodies. - Privacy **4.5**: plaintext exists in worker memory for milliseconds; Cloudflare is the mail handler. Honest wording: "we cannot read it after delivery", not "no server". - Cost: Cloudflare inbound email is free and unlimited; Workers Paid **\$5/mo = \$60/yr flat** at 50,

500 or 5,000 users (150k emails/mo is 1.5% of the included requests).

<https://developers.cloudflare.com/email-service/platform/pricing/>

<https://developers.cloudflare.com/workers/platform/pricing/> - No Google OAuth, no app review, no CASA, no Google Cloud project. Google verifies the address, not you.

<https://support.google.com/mail/answer/10957> - Works for Gmail and Outlook.com. iCloud rule forwarding: not confirmed, test it. - Build: 8–14 days. Needs an in-app screen to show the user Google's forwarding confirmation code (it arrives at the inbound address). - Friction: Gmail filters can only be created on a computer, not in the mobile app. Workspace admins can block external forwarding. Outlook.com sometimes auto-disables forwarding rules (reports Apr 2026). - Must rewrite privacy.html ("Sortd has no server" appears four times) and the App Review notes.

Other inbound providers (all worse on privacy: they store the message): | Provider | Yearly at 50 / 500 / 5,000 users | Retention | |---|---|---| | Postmark Pro | \$198 / \$276 / ~\$2,382 | 45 days default, 7-day minimum paid add-on | | Mailgun | ~\$180 / ~\$420 / ~\$1,750 | up to 3 days if stored | | SendGrid | ~\$1,079 flat (Inbound Parse needs Pro \$89.95/mo) | — | | AWS SES | ~\$4 / ~\$35 / ~\$345 + Lambda/S3 | you control it; more moving parts |

D. Outlook / Hotmail via Microsoft Graph Mail.Read , on device

- Privacy 5. Cost \$0: publisher verification and partner enrolment are free.
- Needs: a work/school Entra account on sortd.page (personal Microsoft accounts cannot be verified), a verified partner org (KV Engineering fits), 3–5 business days.
<https://learn.microsoft.com/en-us/entra/identity-platform/publisher-verification-overview>
- No security assessment found for consumer accounts. Not confirmed on a Microsoft page.
- Build 5–8 days. Only helps Outlook users.

E. Apple Pay tap logging via Shortcuts (already built)

- Privacy 5. Cost \$0.
- Catches in-store Apple Pay taps only. Not online, not physical card, not Watch/Mac.
- Known bugs: blank merchant / zero amount, timeouts, fires on declined payments.
<https://developer.apple.com/forums/thread/765516>
- Country list not published by Apple. Singapore is on one app's list; Australia not confirmed either way.

F. Apple FinanceKit

- Privacy 5 (Apple never sees it). Cost \$0.
- **US only** (Apple Card/Cash/Savings) and **UK only** (13 banks via open banking). No AU, no SG, none announced. <https://developer.apple.com/financekit/>
- Needs entitlement per bundle ID, Finance category, US/UK App Store, likely a legal entity. Cannot be tested from Melbourne or Singapore (no simulator support, needs a real US/UK card).
- Add later for US/UK. Cannot be the foundation.

G. Share extension / PDF

- Privacy 5. Cost \$0. Build 3–5 days.

- Apple Mail and Gmail iOS have no "share this email". Path is Print → pinch → Share, which hands Sortd a PDF. Also works for PDF invoices, screenshots, selected text.
- Manual, 3–5 taps per receipt. Good fallback, not a primary channel.

H. Bank feeds via an aggregator (needs a small server)

Australia (CDR). Go the **CDR representative** route: no accreditation, a contract with an accredited provider, adopt their CDR policy, no ACCC fee, no audit of your own. Basiq says access "in as little time as a week". Becoming accredited yourself costs \$100k–300k; don't. -

<https://www.oaic.gov.au/consumer-data-right/guidance-and-advice/cdr-representative-model-privacy-obligations-of-cdr-representatives> - <https://www.basiq.io/resources/open-banking-access-models.html>

Provider	Price	Notes
Basiq	\$0.50/user/mo + platform fee (not published), 12-month minimum , billed per user for the full month	Only one with a public price. Hosted consent page, no native SDK. Free sandbox. https://www.basiq.io/pricing/
Fiskil	quote only	Best privacy story: onshore only, destroys data "within seconds" of consent ending. https://www.fiskil.com/legal/cdr-policy
Frollo	quote only	Only one with a native Swift SDK
Adatree, Yodlee, Mastercard, illion	quote only	—

All ADIs are mandated data holders, so big 4, ING, Macquarie, Up, ubank are all covered. CDR consent expires at 12 months and must be re-granted. Screen scraping is not banned as of Sep 2026 but is on policy death row and needs bank passwords. Don't.

Singapore. No open banking mandate. DBS/OCBC/UOB APIs are corporate or mock-only. SGFinDex carries month-end balances, not transactions, and non-FI apps cannot join. Singpass MyInfo has no bank data. Banks can cut aggregators off at will (DBS did to Seedly and Planner Bee). Seedly shut its app on 31 Dec 2025. | Provider | Price | Coverage | ---|---|---| | **Finverse** | **US\$0.50 per connected account**, no setup fee, free trial; monthly minimum "transparent" but not published; billing period not stated | DBS, OCBC, UOB, Citi (individual). No POSB, Amex, Trust, GXS, MariBank. WebView only. <https://www.finverse.com/bank-data-api> | | Salt Edge | quote only | 11 SG banks, all credential scraping; logs kept 5 years; EU hosting | | Brankas, Yodlee, Plaid | — | no SG coverage |

US/UK. | Provider | Price | ---|---| | **Teller (US)** | **free to 100 connections** for independent developers, then **\$0.30/enrollment/mo**. Native Swift. <https://teller.io> | | Plaid | no prices published; 10 free trial items; no AU, no SG | | TrueLayer, Salt Edge (UK) | quote only; UK needs FCA agent status | | GoCardless Bank Account Data | closed to new signups since Jul 2025 |

Bank feed cost estimate (per-user rate only; platform fees and minimums excluded because nobody publishes them, and at 50 users they will dominate): | Users | Basiq AU | Finverse SG | Teller US | ---|---|---| | 50 | \$25/mo + platform fee | US\$25/mo + minimum | \$0 | | 500 | \$250/mo + platform fee | US\$250/mo | \$150/mo | | 5,000 | \$2,500/mo + platform fee | US\$2,500/mo | \$1,500/mo |

Privacy. Under CDR the provider must receive the data before passing it to you. You can keep your server to tokens only and pass transactions straight to the phone, encrypted. The provider still sees everything but must delete on consent end (Fiskil, Basiq). Finverse keeps retrieved data with no stated period and transfers across borders. Privacy 3 at best.

I. Not worth doing

- Gmail via IMAP with app password: clunky, full mailbox access, Google can remove it.
- Gmail via IMAP OAuth: needs `mail.google.com`, also restricted.
- Yahoo: no self-serve access, commercial agreement required.
- Gmail add-on: a different product, not an iOS app.

4. What other apps do

None of the mainstream trackers visibly read Gmail. They use bank aggregators and keep data on their own servers.

App	Source	Countries	Privacy
Copilot Money	Plaid, MX, Mastercard, FinanceKit	US	server; "does not sell"
Emma	TrueLayer, Plaid	UK, US, CA	server; shares with TransUnion for credit score
Spendee	Salt Edge, Plaid	EU-strong	server
PocketSmith	Yodlee, Plaid, Salt Edge, Akahu, Basiq (AU)	global	server, encrypted at rest
Frollo	own CDR accreditation	AU	server; keeps de-identified spend data
WeMoney	own CDR accreditation	AU	server; trains categoriser on de-identified data
YNAB	Plaid, MX, FinanceKit	US + some EU	server
Monarch	Plaid, MX, Finicity, FinanceKit	US	server
Rocket Money	Plaid	US	server; shares aggregated data
Cleo	Plaid	US, UK	server; data used for ad targeting (Common Sense Media)
Buddy	Klarna Kosma, Plaid	SE, AU, US...	server (US)
MoneyWiz	Plaid, Yodlee, Salt Edge	global	local + encrypted cloud sync
Seedly (SG)	Salt Edge; DBS cut it off	SG	app closed 31 Dec 2025
Dobin (SG)	bank links + PDF statements	SG	mostly on device; bank logins in Keychain; user-only-decrypt backups. Closest to Sortd's model.
Expensify	forward to <code>receipts@expensify.com</code> , OCR, card feeds	global	server
Shoeboxed	Gmail OAuth, forwarding	US	server; no CASA mention
Klarna	Gmail/Outlook OAuth "Email Connect"	US, UK	server; no public CASA letter
Fetch Rewards	linked email, receipt scan	US	shares purchase history with brands

App	Source	Countries	Privacy
Synceipt	Gmail/Outlook read-only + Plaid	—	server; passed CASA Tier 2 via TAC, Apr 2026
Booksmate	Gmail extraction	—	server; says CASA Tier 2 certified
SubRadar, Receivei, QuickReceipts (iOS)	Gmail <code>gmail.readonly</code> on device	—	on-device only; no verification or CASA mention found
Subik	Gmail on device, list sent to server	—	asked Google about CASA 19 Sep 2026; no answer

Takeaways: the only public CASA passes are small receipt apps. The on-device iOS Gmail apps say nothing about verification, so their status is unknown. Email forwarding (Expensify model) avoids Google's review entirely.

5. Legal (brief, not legal advice)

- **Australia:** Privacy Act small-business exemption (turnover $\leq$ \$3m) likely covers Sortd today. Claims that it ends Dec 2026 are not confirmed on OAIC pages. The statutory tort for serious invasions of privacy (since 10 Jun 2025) applies regardless. Follow the 13 APPs voluntarily. <https://www.oaic.gov.au/privacy/privacy-legislation/the-privacy-act/rights-and-responsibilities>
 - **Singapore:** PDPA has no small-business exemption. If Sortd is run through a Singapore entity, you must name a DPO and publish a business contact on the site (PDPC has fined SMEs S\$5k–30k for missing this). Breach notification within 3 days. Free to add.
 - CDR representative: adopt the principal's CDR policy; extra obligations, no fee.
-

6. Plans and total yearly cost

Fixed costs for every plan: Apple Developer \$99/yr, sortd.page ~\$12–20/yr (exact .page price not confirmed).

Plan 1 — Free (recommended start): ~\$160–175/yr total A (ask exemption) + C (Cloudflare forwarding inbox) + E (Wallet, done) + G (share extension). Flat at 50, 500, 5,000 users. No annual audit. No Google dependency for new users. Build ~10–16 days.

Plan 2 — Mid: same money, +6 days Plan 1 + D (Outlook on device). Needs Entra tenant on sortd.page and a verified partner org.

Plan 3 — Full: \$834–1,014 year one, \$774–954 after Plan 2 + B (CASA Premium \$855). Only if Google refuses the exemption AND Gmail one-tap sign-in measurably beats the forwarding flow for users. Buys convenience, not privacy.

Plan 4 — Bank feeds (later, AU first): unknown until quotes CDR representative under Basiq or Fiskil. Basiq \$0.50/user/mo + platform fee + 12-month minimum. Get platform-fee quotes from Basiq, Fiskil, Frollo. Finverse for SG (US\$0.50/account; confirm minimum and sole-proprietor eligibility). Teller for US (free to 100). Needs a server holding tokens only. Add FinanceKit for US/UK once there is an entity and App Store presence.

7. Recommendation

1. **Today:** reply to Google with the privacy fix and the exemption request (drafted). Free, may save \$855/yr forever.
2. **Now, regardless of Google's answer:** build C, the Cloudflare forwarding inbox. \$60/yr flat, one channel for Gmail + Outlook + anything, no company's permission needed. Wallet taps cover in-store; forwarding covers online receipts. Together they replace the Gmail scan.
3. **Keep Gmail OAuth in the app while the review is pending.** If Google refuses and you don't want to pay, remove it and point users to forwarding. If they grant the exemption, keep both.
4. **Email Basiq, Fiskil, Frolo and Finverse for quotes** now. Cheap to ask, and the platform fee decides whether bank feeds are viable at your size.
5. Rewrite privacy.html and App Review notes before shipping C: "no server" becomes "our server holds only encrypted receipts it cannot read, deleted after delivery".

Open questions (not confirmed)

- Google's actual answer on the exemption.
- Basiq platform fee and currency; Finverse minimum and billing period.
- Whether Fiskil/Basiq accept a one-person app as a representative.
- iCloud Mail rule forwarding to external addresses.
- Apple Pay Shortcuts automation in Australia.
- Whether Microsoft requires any assessment for consumer Mail.Read.